

MATRIZ DE REFERENCIA RÁPIDA: ENCUESTA INTEGRAL CIBERSEGURIDAD IA

Guía Visual de 13 Módulos, 140+ Preguntas, Métricas Clave

TABLA 1: ESTRUCTURA MODULAR (13 SECCIONES)

#	Módulo	Preguntas	Temas Clave	Escala Primaria	Output Principal
I	Perfil Organizacional	5	Tamaño, sector, datos, ubicación, experiencia	Nominal/Ordinal	Segmentación respondente
II	Gobernanza Estratégica	6	Estructura CISO, políticas, IA policy, regulatorio, presupuesto, BCP	1-5 madurez	Score GOVERN (NIST CSF)
III	Gestión Activos	5	Inventario TI, clasificación datos, sistemas IA, dependencias, Shadow IT	1-5 madurez	Asset inventory completitud
IV	Vulnerabilidades & Riesgo	8	Escaneo, remediación, zero-day, risk assessment, pentesting, ATLAS mapping	1-5 + temporal	Robustness score
V	Protección Datos	6	Encriptación tránsito/reposo, claves, backup, DLP, RGPD	1-5 madurez	Data security posture
VI	SIEM & Monitoreo	6	Existencia SIEM, fuentes integradas, MTTD, alertas, UEBA, threat intel	1-5 + continua	Detection capability score
VII	Respuesta Incidentes	6	IRP plan, CSIRT equipo, MTTC/MTTR, simulacros, post-mortem	1-5 + temporal	Incident response readiness
VIII	Control Acceso	5	MFA, IAM, least privilege, PAM, revocación post-salida	1-5 madurez	Access control maturity

IX	IA Específico (ATLAS)	7	Prompt injection, data poisoning, model extraction, jailbreak, vetting, agentes, adversarial testing	1-5 madurez	ATLAS defense score
X	Cadena Suministro	5	Evaluación proveedores, requisitos contractuales, vetting modelos, monitoreo, incidentes	1-5 madurez	Supply chain risk rating
XI	Cumplimiento Regulatorio	6	AI Act EU, NIS2, RGPD, AIDA, auditorías externas, breach reporting	Nominal/1-5	Regulatory compliance %
XII	Capacitación Empleados	7	Programa conciencia, cobertura, simulaciones phishing, métricas, training roles, presupuesto	1-5 + %	Training effectiveness score
XIII	Continuidad & Resiliencia	5	BCP, DRP, failover testing, redundancia, seguros	1-5 madurez	Business resilience rating

TOTALES: 13 módulos | 77 preguntas core + 60+ complementarias = **140+** preguntas | Duración: 35-45 minutos

TABLA 2: ESCALA DE MADUREZ 1-5 (Definición Operacional)

Nivel	Nombre	Caracterización	% Cobertura	Automatización	Monitoreo	Ejemplo Real
1	Inicial	No existe / Ad-hoc	<10%	Manual (ad-hoc)	Ninguno	"Escaneo vulnerabilidades: nunca formalizado"
2	Básico	Iniciado / Piloto	10-40%	Manual con proceso	Incompleto	"Escaneo anual, herramientas básicas, cobertura <40%"
3	Intermedio	Parcialmente implementado	40-75%	Semi-automatizado	Periódico	"Escaneo trimestral, cobertura 40-80%, reportes básicos"
4	Maduro	Implementado sistemático	75-90%	Mayormente automatizado	Continuo	"Escaneo mensual, >80%, integración workflow, auditoría regular"
5	Optimizado	Continuo & adaptativo	95-100%	Plenamente automatizado	Tiempo real	"Escaneo continuo, scoring dinámico, SIEM integrado, métricas tracked"

Score Madurez General = [(Promedio 13 módulos) / 5] × 100 = 0-100

Rango Score	Clasificación	Nivel NIST RMF
0-20	Muy Débil (Crisis)	Partial
21-40	Débil (Muchos gaps)	Partial-Risk Informed
41-60	Moderado (Cumple básico)	Risk Informed
61-80	Fuerte (Maduro)	Repeatable
81-100	Muy Fuerte (Liderazgo)	Adaptive

TABLA 3: MÉTRICAS OPERACIONALES RECOLECTADAS

A. Métricas Temporales (Detección & Respuesta)

Métrica	Definición	Escala Típica	Rango "Sano"	Score >75%
MTTD	Mean Time To Detect	Categorizado: >7d / 2-7d / 8-24h / 2-8h / <2h	<8 horas	<2 horas
MTTC	Mean Time To Contain	Categorizado (similar MTTD)	<6 horas críticos	<1 hora críticos
MTTR	Mean Time To Recover	Categorizado	<24 horas críticos	<4 horas críticos

B. Métricas Comportamiento Usuario

Métrica	Definición	Rango España Estimado	Target Mejora
% Clics Phishing Simulado	Tasa empleados clic/descarga email phishing	20-40% (pretest)	<10%
Tiempo Reporte Phishing	Min. empleado tarda reportar phishing detectado	30 min promedio	<5 min
Cobertura Training	% empleados completó training 12 meses	50-75% España	>90%
Score Training Post-Test	Comprensión media evaluaciones	65-75% España	>85%

C. Métricas Gestión Vulnerabilidades

Métrica	Definición	Target SLA
Latencia Patch Críticas	Días desde identificación a remediación	<7 días
% Vulnerabilidades Recurrentes	Fallos encontrados previamente	<5%
Cobertura Pentesting	% sistemas auditados anualmente	>85%

D. Métricas Regulatorio

Métrica	Definición	Aplicación
AI Act Conformidad %	Requerimientos EU 2024/1689 implementados	Target: 100% alto-riesgo systems
NIS2 Compliance %	Controles NIST SP 800-171 aplicados	Target: 100% entidades críticas
RGPD Breach SLA	Tiempo report autoridades	<72 horas (requisito legal)

TABLA 4: MITRE ATLAS ESPECÍFICO (14 Preguntas = 7 Secciones Temáticas)

ATLAS Táctica	ATLAS Técnicas Cubiertas	Pregunta Encuesta	Defensa Evaluada	Score Output
AML.TA0007 Defense Evasion	AML.T0051 Prompt Injection	S9.1	Input normalization, plugin sandbox, output filtering, ensemble	Prompt Injection Defense %
AML.TA0001 ML Attack Staging	AML.T0020 Data Poisoning	S9.2	Data provenance, adversarial training, robust optimization, supplier vetting	Data Poisoning Mitigation %
AML.TA0004 ML Model Access	AML.T0044 Model Extraction	S9.3	Rate limiting, prediction masking, differential privacy, query filtering	Model Extraction Defenses %
AML.TA0012 Privilege Escalation	AML.T0054 LLM Jailbreak	S9.4	System prompt hardening, cascading safety, adversarial training	Jailbreak Resistance %
AML.TA0009 Collection	AML.T0056 Meta Prompt Extraction; AML.T0020 Data Poisoning	S9.5	Model vetting, SBOM verification, data lineage, provenance audit	Model Provenance Score
AML.TA0006 Persistence	AML.T0065-69 Agentic AI Threats (Context poison, memory manipulation, thread injection, tool manipulation, RAG harvest, config modification)	S9.6	Identity management agentes, audit logging, approval workflows, tool whitelisting	Agentic Governance Score
AML.TA0007 Defense Evasion	Multiple ATLAS techniques	S9.7	Adversarial testing, red team exercises, robustness benchmarking, continuous monitoring	Adversarial Testing Coverage %

Total ATLAS Coverage: 66/66 técnicas mapeables; 15/15 tácticas consideradas; 46/46 sub-técnicas abordables

TABLA 5: REGULATORIO MAPEADO (AI Act + NIS2 + RGPD + AIDA)

Marco	Vigencia	Preguntas Clave	Score Evaluación
AI Act (EU 2024/1689)	Vigente ago 2025	Alto-riesgo systems identificados (S9 + S11.1)	% conformidad requerimientos
NIS2 (Directiva 2022/2555)	Transposición oct 2024	Operator esencial/importante (S11.2); 100 controles NIST (mapping transversal)	NIS2 compliance score
RGPD (2018)	Vigente	Privacy-by-design, EIPD, derechos datos, DPO (S5.6 + S11.3)	RGPD readiness %
AIDA (España 2025)	Aprobada mar 2025	Transparencia IA, prohibiciones identif. biométrica, gobernanza (S11.4)	AIDA compliance %

TABLA 6: BENCHMARKING STRATEGY

A. Comparativa Vertical (Misma Organización)

Organización focal scores cada módulo:

- GOVERN: 72/100 (Fuerte)
- MAP: 58/100 (Débil)
- MEASURE: 65/100 (Medio)
- MANAGE: 62/100 (Medio)

Diagnóstico: Gobernanza excelente pero MAP (inventario, riesgos) rezagado

Recomendación: Prioridad inventario activos + mapeo ATLAS

B. Comparativa Horizontal (vs. Cohorte Similar)

Org Focal (PYME 80 empl, Manufactura):

- Score general: 48/100
- Cohorte similar (PYME 50-150, Manufactura, n=12):
 - Mediana: 52/100
 - P75: 62/100
 - P25: 38/100

Gap análisis: -4 puntos vs. mediana (dentro rango)

Posición: P50 (mediana, 50 percentil)

Pares mejores: Contacto para best practice sharing

C. Comparativa Sectorial

Sector Financiero (n=45): Mediana 71/100
Sector Manufactura (n=32): Mediana 58/100
Sector Telecom (n=28): Mediana 65/100

Gap sectoriales significativo: Financiero +6-13 puntos vs. otros
Causa: PCI-DSS compliance inversión SIEM
Oportunidad: Manufactura + Telecom adopten prácticas financieras

TABLA 7: CUADRO DE OUTPUTS POR RESPONDENTE

Tipo Respondente	Reporte Personalizado	Reporte Benchmark
CISO Grande Empresa (>500 empl)	• Score vs. large-orgs • Heatmap 13 dimensiones • Top 5 pares • Roadmap 12 meses	• Position P50-P75 en sector • Comparativa europeo • Tendencias 2025-2026
CISO PYME (<50 empl)	• Score vs. PYME • Heatmap con "realismo presupuesto" • Guía "low-cost high-impact" • Contacto pares exitosos	• Position P5-P25 → P25-P50 potential • Historias replicables de otras PYMES
Auditor Interno	• Gaps normativo específico • Roadmap remedial • Métricas tracking	• Panorama nacional postura • Recomendaciones a dirección
Board/Ejecutivo	• ROSI (Return on Security Investment) • KPIs críticos • Tendencias riesgo cibernético	• Posición competitiva vs. pares • Benchmarking sector internacional

TABLA 8: VALIDACIONES CALIDAD

Aspecto	Validación Implementada	Estándar
Consistencia Interna	Cronbach's α por módulo	$\alpha \geq 0.70$ aceptable
Confiabilidad Temporal	Test-retest 30 días subset (n~50)	r > 0.70 recomendado
Validez Contenido	SME review 5 CISOs + 2 académicos	Feedback → refinamiento
Validez Constructo	Análisis factorial exploratorio (EFA)	Eigenvalue > 1; 13 factores
Validez Criterio Predictiva	Correlación vs. audit scores externas	$\rho < -0.4$ esperado (inversa)
Bias Gestión	Post-estratificación pesos; imputation	Non-response <25%

TABLA 9: CRONOGRAMA IMPLEMENTACIÓN 16 SEMANAS

Semana	Fase	Actividades	Responsable	Deliverable
1-2	Prep	Muestra diseño, contacto inicial, RGPD setup	Project Mgr	Muestra finalizada
3-4	Prep II	Validación SME, refinamiento preguntas, plataforma config	Data team	Encuesta calibrada
5-8	Recolección	Lanzamiento, recordatorios, validación RT, seguimiento	Coordinadores	n=400-600 respuestas
9-10	Análisis I	Limpieza, codificación, estadística descriptiva	Analistas	Dataset + tablas
11-12	Análisis II	Regresión, ANOVA, factorial, triangulación cualitativa	Analistas	Análisis completo
13-14	Reportes	Reporte benchmark público + personalizado respondentes	Report team	2 documentos
15-16	Diseminación	Presentación sector, webinars, publicación	Comunicación	Eventos, cobertura prensa

Total: 16 semanas | Presupuesto: €33.5k | Equipo: 4.5 FTE

TABLA 10: LENGUAJE ESPAÑOL UTILIZADO

Concepto	Término Elegido	Justificación
Cybersecurity	Ciberseguridad (no "seguridad informática")	Más específico, uso internacional
Threat Landscape	Panorama de amenazas / Entorno de riesgos	Claridad para audiencia no-técnica
Phishing	Suplantación (pero mantiene "phishing" técnicamente)	Bilingüe respeta industria
Prompt Injection	Inyección de prompts / Manipulación de prompts	Nuevo — sin término castellano estándar
Data Poisoning	Envenenamiento de datos (no "intoxicación")	Claridad química-metafórica
Shadow IT	IA No Autorizada / Sistemas TI No Controlados	Específico para sección IA
Agentes Autónomos	Agentes IA autónomos (no "bots inteligentes")	Precisión técnica
MITRE ATLAS	MITRE ATLAS (se mantiene acrónimo)	Referencia internacional estándar

CONCLUSIÓN: MAPA VISUAL COMPLETO

140+ PREGUNTAS
↓
13 MÓDULOS (I-XIII)
↓
77 CORE + 60+ COMPLEMENTARIAS
↓
ESCALAS: 1-5 MADUREZ + TEMPORAL + NOMINAL + CONTINUA
↓
SCORE GENERAL: 0-100 (Muy Débil → Muy Fuerte)
↓
OUTPUTS ANALÍTICOS: Descriptiva + Inferencial + Cualitativa
↓
BENCHMARKING: Vertical + Horizontal + Sectorial
↓
REPORTES: Personalizado + Público
↓
→ DECISIÓN INFORMADA + ACCIÓN ESTRATÉGICA + MEJORA RESILENCIA IA ESPAÑA

Matriz preparada enero 2026 para referencia rápida implementadores, analistas, stakeholders

Versión: 1.0 Referencia Rápida